



[Security and Privacy \(secpriv-module.html\)](#) > [Security \(security.html\)](#) > **Security Labels**

This page is part of the FHIR Specification (v4.0.1: R4 - Mixed [Normative \(https://confluence.hl7.org/display/HL7/HL7+Balloting\)](https://confluence.hl7.org/display/HL7/HL7+Balloting) and [STU \(https://confluence.hl7.org/display/HL7/HL7+Balloting\)](https://confluence.hl7.org/display/HL7/HL7+Balloting) in it's permanent home (it will always be available at this URL). The current version which supercedes this version is [5.0.0 \(http://hl7.org/fhir/index.html\)](http://hl7.org/fhir/index.html). For a full list of available versions, see the [Directory of published versions \(http://hl7.org/fhir/directory.html\)](http://hl7.org/fhir/directory.html). Page versions: [R5 \(http://hl7.org/fhir/R5/security-labels.html\)](http://hl7.org/fhir/R5/security-labels.html), [R4B \(http://hl7.org/fhir/R4B/security-labels.html\)](http://hl7.org/fhir/R4B/security-labels.html), **[R4 R3 \(http://hl7.org/fhir/STU3/security-labels.html\)](http://hl7.org/fhir/STU3/security-labels.html)**, [R2 \(http://hl7.org/fhir/DSTU2/security-labels.html\)](http://hl7.org/fhir/DSTU2/security-labels.html)

6.1.1_Security Labels

FHIR Infrastructure (http://www.hl7.org/Special/committees/fiwc/index.cfm) Work Group	Maturity Level (versions.html#maturity): 3	Standards Status (versions.html#std-process): Trial Use (versions.html#std-process)
--	--	---

A security label is a [concept \(datatypes.html#Coding\)](#) attached to a resource or bundle that provides specific security metadata about the information it is fixed to. The [Access Control decision engine \(security.html#access-control\)](#) uses the security label together with any provenance resources associated with the resource and other metadata (e.g. the resource type, resource contents, etc.) to

- approve read, change, and other operations
- determine what resources can be returned
- determine what handling caveats must be conveyed with the data

Security Labels enable more data to flow as they enable policy fragments to accompany the resource data.

The intent of a security label is that the recipient of resources or bundles with security-tags is obligated to enforce the handling caveats of the tags and carry the security labels forward as appropriate.

Security labels are only a device to connect specific resources, bundles, or operations to a wider security framework; a full set of policy and consent statements and their consequent obligations is needed to give the labels meaning. Because of this, security labels are most effective in fully trusted environments - that is, where all trading partners have agreed to abide by them in a Mutual Trust Framework. Note also that security labels support policy, and specific tagging of individual resources is not always required to implement policy correctly.

In the absence of this kind of pre-agreement, Security Labels may still be used by individual parties to assist with security role checking, but they might not all be recognized and enforced, which in turn limits what information can flow.

Local agreements and implementation profiles for the use security labels should describe how the security labels connect to the relevant consent and policy statements, and in particular:

- Which Security Labels are able to be used
- What to do if a resource has an unrecognized security label on it
- Authoring obligations around security labels
- Operational implications of security labels

This specification defines a basic set of labels for the most common use cases trading partners, and a wider array of security labels that allow much finer grained management of the information.

6.1.1.1 Representing Security Labels

A security label is represented as a [Coding \(datatypes.html#Coding\)](#), with the following important properties:

- system The coding scheme from which label is taken (see [code system URI \(terminologies-systems.html\)](#), and below)
- code a code from the coding scheme that identifies the security label and code is a value from the code system
- display The display form for the code (mostly for use when a system doesn't recognize the code)

An example XML Patient Resource with a "Restricted" tag associated with it, as represented in an HTTP response:

```
<Patient xmlns="http://hl7.org/fhir">
  <meta>
    <security>
      <system value="http://terminology.hl7.org/CodeSystem/v3-Confidentiality"/>
      <code value="R"/>
      <display value="Restricted"/>
    </security>
  </meta>
  ... [snip] ...
</Patient>
```

A JSON search result that includes a resource that the receiving application must delete all copies of the resource after using it:

```
{
  "resourceType" : "Bundle",
  "type" : "searchset",
  ... other headers etc.....
  "entry" : [
    ... other entries ....
    {
      "resource": {
        "id" : "1",
        "meta" : {
          "security" : [{
            "system" : "http://terminology.hl7.org/CodeSystem/v3-ActCode",
            "code" : "DELAU",
            "display" : "delete after use"
          }]
        }
        ... other content etc.....
      }
    },
    ... other entries ....
  ]
}
```

Note: the actual terms used in these examples are described below.

The basic framework for security labels is described by the [HL7 Healthcare Classification System](#)

(http://www.hl7.org/implement/standards/product_brief.cfm?product_id=345). This specification identifies how security labels are defined and provides a relatively comprehensive list of labels. All the HCS defined labels (see below for the lists) can be used as security labels on FHIR resources and bundles (e.g. requests and responses).

In addition, other security labels not defined here or in the HCS can be defined by jurisdictions, vendors and/or projects and used as appropriate. However, note

that:

- Defining additional security labels will increase costs associated with information and system portability
- Implementation guides and applications SHOULD always use the applicable label defined by the HCS if one exists

Note: The use of security labels and the expression of common shared security policies is a matter of ongoing discussion and development in several communities.

6.1.1.2 Core Security Labels

This specification defines a set of core security labels for all FHIR systems. All conformant FHIR Applications SHOULD use these labels where appropriate. For all these labels, how they are operationalized - their use and interpretation - is subject to the applicable Mutual Trust Framework agreement as described above.

Name/ Tag	Description
Context of Use	
Purpose of Use	These Purpose of Use (v3/PurposeOfUse/vs.html) (system = http://terminology.hl7.org/CodeSystem/v3-PurposeOfUse) is an indication of a reason for performing one or more operations on information, which may be permitted by source system's security policy in accordance with one or more privacy policies and consent directives. Such as collecting personal health information for research or public health purposes. Notes may be used as: • The rationale or purpose for a request for data • The use limitation on a data Bundle See discussion on HCS below
Data Sensitivity	
Confidentiality codes	These confidentiality class (v3/ConfidentialityClassification/vs.html) (system = http://terminology.hl7.org/CodeSystem/v3-Confidentiality) can be applied to any resource or bundle. They are generally assigned by the author of the resource but can be modified subsequently as a matter of operational management. The Confidentiality classifications describe the sensitivity of the information in a resource about whether it should made available or disclosed to unauthorized individuals, entities, or processes. Notes: • In the absence of a confidentiality code, the basic confidentiality of a resource may be implied by its definition and content; e.g. a patient's condition is far more likely to be confidential than a practitioner resource, and a Diagnostic Report with an HIV test is always highly confidential, whereas a routine electrolytes report is rarely particularly confidential • The confidentiality of a bundle is always as confidential as the most confidential resource in the bundle The additional security labels are more specific to support very specific fine-grained access control and should always be used in association with an appropriate confidentiality label. See discussion on HCS below
Control of Flow	
Delete After Use: ActCode. DELAU (v3/ActCode/cs.html#DELAU)	An application receiving a resource with this label must delete all copies after the immediate use for which the data was exchanged, is complete. Notes: • This may imply a prohibition not storing the resource in any audit trail as well • Additional security labels can make exceptions to the blanket restriction this implies. This allows a resource to be exchanged with a blanket rule not to retain copies unless the exact rules for retaining it can be followed
Do Not Re-use: ActCode. NOREUSE (v3/ActCode/cs.html#NOREUSE)	An application receiving a resource with this label may only use it for the immediate purpose of use. In particular, the application is not authorized to re-distribute (i.e. exchange this resource with any other application). Notes: • The exact interpretation of "immediate purpose of use" and the boundaries of "the application" are determined by local policy • Additional security labels can make exceptions to the blanket restriction this implies. This allows a resource to be exchanged with a blanket rule not to re-use unless the exact rules for doing so can be followed

Test Data: ActCode.HTEST (v3/ActCode/cs.html#HTEST)	This marks that a resource has been created to test an application, and is not real production data Notes: • Most testing is performed on dedicated test systems where all the data is test data • Some testing is performed on production systems, which is where this security label is used • This is a security label because different access control rules may apply to test resources
--	--

6.1.1.3 Break the Glass

There is a special security label to support the commonly encountered "break-the-glass" protocol, where a clinician (usually in an emergency context) requests emergency unauthorized access to the patient's record.

Break the Glass	http://hl7.org/fhir/security-label#break-the-glass	The requester is asking for emergency access for patient treatment. Typically, this means that the patient is unconscious and not able to provide relevant information or consent.
-----------------	---	--

This [purpose of use \(v3/ActReason#BTG\)](http://hl7.org/fhir/terminology/v3/ActReason#BTG) label is represented as a security label on the request, rather than on a resource, and so is represented in the request as a [web category](https://tools.ietf.org/html/draft-johnston-http-category-02) (https://tools.ietf.org/html/draft-johnston-http-category-02):

```
HTTP/1.1 GET fhir/Patient/482735/condition
Content-Type: text/xml
Access-Control-Allow-Origin: *
Last-Modified: Thu, 19 Nov 2013 07:07:32 +1100
ETag: 24
Category: http://terminology.hl7.org/CodeSystem/v3-ActReason#BTG; scheme="http://hl7.org/fhir/tag/security"; label="break the glass"
```



While the principle of break-the-glass is well understood, implementing it well has some challenges. This specification defines a method to represent break-the-glass in an HTTP request, but does not define any policy or protocol around such requests. At a minimum, implementations must ensure:

- How, when and why to initiate the break-the-glass is well understood
- Appropriate authorization, consent checking, and access control is used to ensure it is used properly (e.g. if using OAuth, checking that the Authorization Server allows this)
- Any use is well-represented in an [AuditEvent \(auditevent.html\)](http://hl7.org/fhir/terminology/v3-ActReason#BTG) (todo: profile for break the glass)

See [this paper](http://www.hl7.org/search/viewSearchResult.cfm?search_id=393442&search_result_url=%2Fdocumentcenter%2Fpublic%2Fwg%2Fsecure%2FHL7%20Emergency%20Access%2Edoc) (http://www.hl7.org/search/viewSearchResult.cfm?

search_id=393442&search_result_url=%2Fdocumentcenter%2Fpublic%2Fwg%2Fsecure%2FHL7%20Emergency%20Access%2Edoc) for discussion of the issues involved in break-the-glass operations.

6.1.1.4 Healthcare Privacy and Security Classification System (HCS)

The security labels described above are a subset of the full set of security labels defined by the HL7 [Healthcare Privacy and Security Classification System](http://www.hl7.org/Implement/standards/product_brief.cfm?product_id=345) (http://www.hl7.org/Implement/standards/product_brief.cfm?product_id=345). The HCS defines 5 categories of security labels that may be applied to a resource:

Security Label	Card.	Values	Description
----------------	-------	--------	-------------

Confidentiality Classification	0..1	ConfidentialityClassification (v3/ConfidentialityClassification/vs.html).	Security label metadata classifying an IT resource (clinical fact, data, information object, service, or system capability) according to its level of sensitivity, which is based on an analysis of applicable privacy policies and the risk of financial, reputational, or other harm to an individual or entity that could result if made available or disclosed to unauthorized individuals, entities, or processes. Example Uses: Unrestricted, Normal, Very restricted
Sensitivity Category	0..*	InformationSensitivityPolicy (v3/InformationSensitivityPolicy/vs.html).	Security label metadata that "segments" an IT resource by categorizing the value, importance, and vulnerability of an IT resource perceived as undesirable to share. Example Uses: STDs, Psychiatric care, Celebrity status
Compartment Category	0..*	Compartment (v3/Compartment/vs.html).	Security label metadata that "segments" an IT resource by indicating that access and use is restricted to members of a defined community or project Note: this is a different use of "Compartment" to the Patient Compartment (compartmentdefinition.html) use. Example Uses: Research, HR records
Integrity Category	0..*	SecurityIntegrityObservationValue (v3/SecurityIntegrityObservationValue/vs.html).	Security label metadata that "segments" an IT resource by conveying the completeness, veracity, reliability, trustworthiness, and provenance of an IT resource Example Uses: Anonymized, signed, patient reported
Handling Caveat	0..*	SecurityControlObservationValue (v3/SecurityControlObservationValue/vs.html).	Security label metadata conveying dissemination controls and information handling instructions such as obligations and retention policies to which an IT resource custodian or receiver must comply. This type of handling caveat SHALL be assigned to a clinical fact if required by jurisdictional or organizational policy, which may be triggered by a patient consent directive Example Uses: do not disclose, various restrictions on use, and policy marks

Each of these security labels identifies a [ValueSet](#) ([valueset.html](#)) that lists a set of possible codes for the security label.

6.1.1.4.1 Jurisdiction Specific Security Labels

The HL7 Healthcare Classification System also allows for Realm-specific privacy law or policy category codes for use in security labels in specific domains. These domains are included with this specification:

Security Label	Card.	Values	Description
US Privacy Law	0..*	ActUSPrivacyLaw (v3/ActUSPrivacyLaw/vs.html).	Security label metadata that "segments" an IT resource by indicating the legal provisions to which the assignment of a Confidentiality Classification complies in the US.

© HL7.org 2011+. FHIR Release 4 (Technical Correction #1) (v4.0.1) generated on Fri, Nov 1, 2019 09:37+1100. [QA Page](#) ([qa.html](#))

Links: [Search](#) (<http://hl7.org/fhir/search.cfm>) | [Version History](#) ([history.html](#)) | [Table of Contents](#) ([toc.html](#)) | [Credits](#) ([credits.html](#)) | [Compare to R3](#) (<https://www.fhir.org/perf/htmldiff.pl?oldfile=http%3A%2F%2Fhl7.org%2Ffhir%2FSTU3%2Fsecurity-labels.html&newfile=http%3A%2F%2Fhl7.org%2Ffhir%2FR4%2Fsecurity-labels.html>) |  ([license.html](#)) | [Propose a change](#) (<http://hl7.org/fhir-issues>)